TravelPay — Xəta düzəlişləri və yenilik təklifləri

Layihə: Travel Pay (Laravel backend + React admin panel + istifadəçi SPA) · Tarix: 19.10.2026

1. Qısa xülasə

- Bütün backend testləri əvvəl də keçirdi (24/24). Problemlər testlərin tutmadığı yerlərdə idi: **eyni anda göndərilən sorğularda pulun iki dəfə hərəkət etməsi** (race condition), production-da da işləyən demo 2FA kodu və admin əməliyyatlarında çatışmayan yoxlamalar.
- Düzəlişlərdən sonra: **26/26 test keçir** (yeni testlər əlavə olundu), TypeScript xətasız kompilyasiya olunur, admin panel yenidən build edilib və backend/public/admin qovluğuna köçürülüb.
- Dəyişikliklər hələ commit edilməyib — git diff ilə baxa bilərsiniz.

2. Düzəldilən xətalar

#	Fayl / yer	Problem	Düzəliş
1	WalletService.php — approveHeld / rejectHeld	Status yoxlaması kilidlənmədən (lockForUpdate) əvvəl edilirdi. Admin «Approve» düyməsinə iki dəfə tez bassa, pul alıcıya **iki dəfə** köçə bilərdi.	Status indi sətir kilidləndikdən sonra yenidən yoxlanılır; ikinci cəhd 409 qaytarır.
2	WalletService.php — payRequest (QR ödəniş)	Birdəfəlik şəxsi QR kodu paralel sorğularla **iki dəfə ödənə** bilərdi.	PaymentRequest tranzaksiya daxilində kilidlənir və status yenidən yoxlanılır.
3	BookingService.php — cancel	Paralel «Cancel» sorğuları rezervasiya pulunu **iki dəfə qaytara** bilərdi.	Booking kilidlənir, status kilid altında yoxlanılır.
4	CardController.php — charge	Aylıq limit və «single-use» kart statusu kilidsiz yoxlanılırdı — paralel ödənişlər limiti aşa və birdəfəlik kartı təkrar istifadə edə bilərdi.	Kart kilidlənir, limit və status kilid altında yenidən yoxlanılır.
5	AuthService.php — 2FA	«123456» master kodu **hər mühitdə** (production da daxil) istənilən 2FA-nı keçirdi.	Yalnız local/testing mühitində işləyir (config: travelpay.security.demo_otp_enabled, env: TRAVELPAY_DEMO_OTP).
6	AdminController.php — updateUserStatus	Admin öz hesabını dondura/bloklaya bilirdi; bloklanan istifadəçinin token-ləri aktiv qalırdı (API-dən istifadəni davam etdirirdi).	Öz statusunu dəyişmək qadağandır; suspended/frozen olanda bütün token-lər silinir.
7	AdminController.php — siyahılar	per_page və limit parametrləri məhdudsuz idi (per_page=1000000 bütün cədvəli bir dəfəyə çəkirdi).	per_page 1–100, ledger limit 1–200 arasında məhdudlaşdırıldı.
8	AdminController.php — fraud alert / rule	«investigating» statusunda da resolved_by yazılırdı; qayda və alert dəyişiklikləri audit log-a düşmürdü.	resolved_by yalnız bağlananda yazılır; hər iki əməliyyat audit log-a yazılır.
9	AuthService.php — register	role sahəsi $data['role'] ilə oxunurdu (gələcəkdə admin qeydiyyatına yol açardı).	Qeydiyyatda rol həmişə «user».
10	Admin React — 10 fayl	Lint xəbərdarlıqları: funksiyalar elan olunmadan useEffect-də istifadə olunurdu, dependency-lər çatışmırdı.	useCallback + düzgün sıra; 13 xəbərdarlıqdan qalanlar yalnız üslub məsləhətidir.
11	TransactionsView.tsx	Bütün statuslar yaşıl göstərilirdi; card_payment, booking, refund, crypto filtrləri yox idi; köhnə «Phase 3» mətnləri.	Statusa görə rəng, yeni filtrlər, mətnlər yeniləndi.

Yeni testlər: ikiqat approve-un qarşısının alınması, adminin öz statusunu dəyişə bilməməsi və bloklananda token-lərin silinməsi, demo OTP-nin söndürülə bilməsi.

3. Səhifələr üzrə əlavə edilə biləcək yeniliklər

Prioritet: **Yüksək** — təhlükəsizlik/pul və ya backend-də hazır olub UI-da olmayan funksiya; **Orta** — istifadəçi təcrübəsi; **Aşağı** — gözəl olar.

3.1 Admin panel (React — admin/src/views)

Səhifə	Təklif	Prioritet
Dashboard	14 günlük tranzaksiya qrafiki — backend daily_volume göndərir, amma səhifədə göstərilmir.	Yüksək
	«Held for review» və «KYC verified» KPI kartları (overview-da var, UI-da yox).	Orta
	Son security event-lər lenti (recent_security_events göndərilir, istifadə olunmur).	Orta
	Avtomatik yenilənmə (məs. hər 30 san.) və «son yenilənmə» vaxtı.	Aşağı
Transactions	Held tranzaksiyalar üçün «Approve / Reject» düymələri — API hazırdır (/admin/transactions/{id}/approve|reject).	Yüksək
	Səhifələmə (pagination) — backend meta.last_page qaytarır, UI yalnız 1-ci səhifəni göstərir.	Yüksək
	Tranzaksiya detal paneli: metadata, risk qaydaları, ledger yazıları.	Orta
	Tarix aralığı filtri və CSV/Excel eksport.	Orta
Users	Səhifələmə və istifadəçi detal səhifəsi (cüzdan, cihazlar, KYC, son tranzaksiyalar).	Yüksək
	«Suspend» seçimi (indi yalnız active ↔ frozen); səbəb yazmaq üçün sahə.	Orta
	Bloklamadan əvvəl təsdiq dialoqu.	Aşağı
Fraud Monitoring	Severity və status filtrləri (API dəstəkləyir, UI-da yoxdur).	Orta
	Alert-dən birbaşa tranzaksiyaya keçid və həmin yerdə approve/reject.	Yüksək
	Alert-ə admin qeydi (comment) əlavə etmək.	Aşağı
Risk Rules	Dəyişiklik tarixçəsi — audit log artıq yazılır, sadəcə qayda yanında göstərmək lazımdır.	Orta
	Sandbox simulyasiyası (/admin/sandbox/simulate) ilə qaydanı tətbiq etməzdən əvvəl sınamaq.	Orta
Security Events	Səhifələmə, tarix filtri; IP-yə klikləyəndə bir düymə ilə bloklamaq.	Orta
Wallets / Travel Analytics / Audit Logs	Wallets: admin tərəfindən cüzdanı dondurmaq/açmaq, valyuta üzrə filtr.	Orta
	Travel Analytics: qrafiklər (kateqoriya pie chart, top istiqamətlər bar chart).	Aşağı
	Audit Logs: old/new dəyərlərin diff şəklində göstərilməsi, səhifələmə, eksport.	Orta
Yeni admin səhifələri (React-da yoxdur, backend və köhnə admin.js-də var)	Ledger / Trial balance (/admin/ledger).	Yüksək
	Threat Shield: bloklanmış IP-lər, əl ilə bloklama/açma (/admin/threats, /admin/blocked-ips).	Yüksək
	KYC yoxlamaları (/admin/kyc), Bookings + crypto custody (/admin/bookings), Merchants (/admin/merchants).	Orta

3.2 İstifadəçi tətbiqi (backend/public/js/travelpay)

Səhifə	Təklif	Prioritet
Giriş / Qeydiyyat	«Şifrəni unutdum» axını (e-poçt ilə reset).	**Yüksək**
	E-poçt və ya telefon təsdiqi (OTP).	**Orta**
Dashboard / Wallet	Real vaxt bildirişləri (WebSocket / Laravel Reverb) — hazırda yalnız sorğu ilə.	**Orta**
	Balans qrafiki və aylıq xərc limiti xəbərdarlığı.	**Aşağı**
Send (P2P) / QR	Tez-tez göndərilən alıcılar siyahısı və favoritlər.	**Orta**
	Göndərməzdən əvvəl təsdiq ekranı (alıcının adı, məbləğ, komissiya).	**Orta**
	Qəbz PDF yükləmə / paylaşma.	**Aşağı**
Exchange / Top-up	Real valyuta məzənnəsi API-si (məs. CBAR) və məzənnə tarixçəsi qrafiki.	**Orta**
	Məzənnə xəbərdarlığı (alert) — «USD 1.68-dən aşağı düşəndə xəbər ver».	**Aşağı**
Cards	Kart üzrə tranzaksiya tarixçəsi və kateqoriya üzrə bloklama.	**Orta**
	Aylıq limit heç vaxt sıfırlanmır: spent_this_month üçün scheduler yoxdur — kart limiti dolanda kart birdəfəlik «ölür». Hər ayın 1-i sıfırlayan scheduled command əlavə edin.	**Yüksək**
Trips / Bookings / Places / Crypto / Insights	Trips: büdcə aşılanda bildiriş, səfər üzrə xərc hesabatı PDF.	**Orta**
	Bookings: tarix seçimi üçün təqvim, ləğvetmə qaydaları və qismən geri qaytarma.	**Orta**
	Places: xəritə görünüşü (Leaflet/OpenStreetMap).	**Aşağı**
	Crypto: qiymət qrafiki və portfel gəlir/zərər tarixçəsi.	**Aşağı**
	Insights: ay-ay müqayisə və kateqoriya büdcələri.	**Aşağı**
Security / KYC	2FA-nı söndürmək üçün şifrə və ya kod tələb etmək (hazırda tək kliklə sönür).	**Yüksək**
	Real TOTP (Google Authenticator) + QR kod — hazırda simulyasiyadır.	**Yüksək**
	KYC: sənəd şəklinin yüklənməsi və admin tərəfindən təsdiq/rədd axını.	**Orta**

4. Ümumi texniki tövsiyələr

- **İki admin panel var**: React (admin/) və köhnə vanilla JS (public/js/travelpay/admin.js). Birini seçin — React-a çatışmayan səhifələri köçürüb köhnəni silmək məntiqlidir.
- **mobile/ qovluğu boşdur** — mobil tətbiq planlaşdırılırsa, mövcud /api/v1 API-si üzərində Flutter və ya React Native ilə başlamaq olar.
- **Idempotency**: Idempotency-Key yoxlaması tranzaksiyadan kənardadır; transactions.idempotency_key sütununa UNIQUE indeks əlavə etmək tam qoruma verər.
- **Race testləri**: kilidlər SQLite testlərində işləmir; MySQL üzərində paralel sorğu testi (məs. iki eyni approve) əlavə etmək tövsiyə olunur.
- **Production hazırlığı**: APP_DEBUG=false, TRAVELPAY_DEMO_OTP=false, docker-compose-dakı sadə şifrələri (root123 və s.) dəyişin. (.env git-ə düşmür — yaxşıdır.)
- **CI**: GitHub Actions ilə hər push-da php artisan test + npm run build + oxlint.
- **Dashboard həcm hesabı**: «Completed volume» bütün tipləri (exchange, top-up daxil) toplayır — tiplərə görə ayrı göstərmək daha dəqiq olar.
- **Merchants endpoint-i**: hər merchant üçün ayrı sorğu (N+1) — tək GROUP BY sorğusu ilə əvəz etmək olar.